

OWASP TOP 10

4/18/26 11:06 AM

- Broken Access Control
- Cryptographic Failures
- Injection
- Insecure Design
- Security Misconfiguration
- Vulnerable and Outdated Components
- Identification and Authentication Failures
- Software and Data Integrity Failures
- Security Logging and Monitoring Failures
- Server-Side Request Forgery

1. A01:2021 – Broken Access Control

What it is: Users can access or perform actions they should not be allowed to (e.g., viewing another user's data or admin functions). **Why it matters:** It is the #1 risk because it directly violates the principle of least privilege. **What it covers:** Missing authorization checks, forced browsing, IDOR (Insecure Direct Object Reference), and privilege escalation. **Real-world example:** A regular user changes the URL from /user/123/profile to /user/456/profile and views another user's private data.

Interview tip: "This is when authorization is broken — the system doesn't properly check what the user is allowed to do."

2. A02:2021 – Cryptographic Failures

What it is: Failures in encryption, hashing, or key management that expose sensitive data. **Why it matters:** Leads to data breaches (credit cards, passwords, PII). **What it covers:** Weak algorithms (e.g., MD5, SHA-1), missing encryption in transit/storage, poor key management. **Real-world example:** A website stores passwords using unsalted MD5 hashes. An attacker steals the database and cracks them easily.

Interview tip: "This replaced Sensitive Data Exposure. It's about using proper cryptography to protect data at rest and in transit."

3. A03:2021 – Injection

What it is: Untrusted data is sent to an interpreter (SQL, OS commands, LDAP, etc.) without proper validation. **Why it matters:** Can lead to full system compromise or data theft. **What it covers:** SQL injection, command injection, XSS (now included here), and other injection attacks. **Real-world example:** Attacker enters ' OR '1'='1 in a login form and bypasses authentication.

Interview tip: "Injection happens when user input is not sanitized before being passed to a database or command shell."

4. A04:2021 – Insecure Design

What it is: Flaws in the overall design or architecture of the application. **Why it matters:** These are hard to fix later because they are built into the foundation. **What it covers:** Missing threat modeling, lack of secure-by-design principles, weak business logic. **Real-world example:** An app allows password reset with only a token but no user ID check, allowing attackers to reset any account.

Interview tip: "This is a new category. It focuses on design-level problems that can't be fixed with just code patches."

5. A05:2021 – Security Misconfiguration

What it is: Incorrect or insecure setup of servers, frameworks, or applications. **Why it matters:** One of the most common and easiest ways attackers gain initial access. **What it covers:** Default credentials, unnecessary features enabled, misconfigured permissions, exposed error messages. **Real-world example:** A server has directory listing enabled, so attackers browse /admin or /backup folders.

Interview tip: "This is everything from leaving default passwords to having debug mode on in production."

6. A06:2021 – Vulnerable and Outdated

Components

What it is: Using libraries, frameworks, or software with known vulnerabilities. **Why it matters:** Attackers scan for known CVEs and exploit them automatically. **What it covers:** Unpatched third-party components, missing dependency scanning. **Real-world example:** Using an old version of Log4j (Log4Shell) that allows remote code execution.

Interview tip: "Always scan dependencies with tools like OWASP Dependency-Check or Snyk."

7. A07:2021 – Identification and Authentication

Failures

What it is: Weaknesses in login, session management, or password handling. **Why it matters:** Leads to account takeover and credential stuffing. **What it covers:** Weak passwords, no MFA, poor session handling, credential stuffing. **Real-world example:** No rate limiting on login → attacker brute-forces passwords or uses stolen credentials from breaches.

Interview tip: "This includes broken authentication and session management from older versions."

8. A08:2021 – Software and Data Integrity Failures

What it is: Failures in verifying the integrity of code or data (e.g., insecure deserialization, untrusted updates). **Why it matters:** Attackers can supply malicious code or data that the app trusts. **What it covers:** Insecure deserialization, CI/CD pipeline attacks, unsigned software updates. **Real-world example:** An app deserializes user-uploaded objects without validation, allowing remote code execution.

Interview tip: "This is about trusting data or code that hasn't been properly verified."

9. A09:2021 – Security Logging and Monitoring

Failures

What it is: Insufficient or missing logging and monitoring. **Why it matters:** You can't detect or respond to attacks if you don't see them. **What it covers:** No logging of security events, weak monitoring, missing alerts. **Real-world example:** An attacker breaches the system, but no logs exist, so the incident goes undetected for months.

Interview tip: "If you don't log and monitor security events, you have no visibility into attacks."

10. A10:2021 – Server-Side Request Forgery (SSRF)

What it is: The server is tricked into making requests to internal or external resources the attacker controls. **Why it matters:** Can bypass firewalls and access internal systems (metadata services, internal APIs). **What it covers:** Attacker supplies a URL that the server fetches. **Real-world example:** Attacker enters <http://169.254.169.254/latest/meta-data/> in a URL field; the server fetches AWS credentials.

Interview tip: "SSRF lets attackers make the server request internal resources it shouldn't reach."